Protecting SaaS behaviour from REA-assisted reconstruction

Combined-defence research edition | 19 October 2026

At the 192-request checkpoint, unrestricted exact estimates allowed **100.0% exact reconstruction** and **100.0% within-5% reconstruction** on six withheld synthetic pricing targets. The largest observed mean reduction in within-5% accuracy was **81.7 percentage points** for **Approved outputs only**, leaving 18.3% accuracy. These are one-attempt-per-cell results, not a universal ranking.

For the direct combination test, **GBP 1,000 rounding plus the eight-quantity cap left 39.6% within-5% reconstruction accuracy**, compared with 88.2% for rounding alone and 60.0% for the cap alone. It reduced within-5% accuracy below both single-control attempts on **5/6 targets**. The combination passed the short-workflow usefulness criterion on **0/6 targets**. The paired differences and target ranges below show whether the average benefit was consistent.

Among defended arms meeting the predeclared short-workflow criterion on all six targets, **Eight-quantity cap** had the largest observed mean within-5% reduction: **40.0 percentage points**, leaving 60.0% reconstruction accuracy. This is a result for the six-estimate workflow; the longer and exhausted-user workloads below reveal additional costs.

None of the three tested combined configurations passed the short-workflow usefulness criterion on all six targets. Coarse rounding plus cap passed 0/6; gentle rounding plus cap and gentle rounding plus catalogue each passed 4/6. The quota-only configuration passed the short journey, but refused one third of longer planning estimates and every estimate requested by the second session after exhaustion. All 672 approved quote/export actions across the 168 journeys returned the correct exact result.

A post-run strategy diagnostic found that 5/6 quota-only agents and 5/6 coarse-rounding-plus-cap agents spent all eight distinct estimate observations in their first batch. The gentle-rounding-plus-cap count was 2/6. The 16-request batch option was available, not required; these were agent choices. This limits adaptive selection before discovering the cap, but this run does not isolate how much it explains. The earlier agent study reached 95.6% within-5% accuracy under an eight-quantity cap with different targets, settings and a smaller batch option. The new 60.0% quota result does not overturn that evidence or establish a reliable protection bound. Test an attacker that knows the cap and chooses its eight queries carefully before relying on it.

What protection means

Authentication and authorisation can hard-block specific unauthorised requests. They cannot prevent an entitled browser from seeing permitted outputs. Keeping an implementation on the server removes direct code disclosure but still permits inference from examples. The engineering question is how much useful information to release, through which workflows, and at what customer cost. This study measures that trade-off; it does not establish a universal way to make a SaaS product impossible to recreate.

REA (Reverse Engineer Anything) provides inspection and reverse-engineering tools. In this study an LLM selects quantities, workflows and sessions. Its bounded tool wrapper invokes real REA 6.7.0 capture-browser-scenario in Chrome, fills inputs, selects a route, clicks Calculate and retains DOM and network artifacts. The wrapper returns captured observations, including delivered JavaScript when inspected. The LLM reasons over those observations and emits a validated piecewise numeric predictor. REA does not magically recover a hidden server implementation: it exposes what the entitled browser can observe, which the agent uses to infer behaviour. The evaluator runs no agent-authored executable code. This is actual REA-assisted inference under a bounded interface, not every upstream REA capability or an unconstrained attacker.

Stronger agent effort and larger allowances

The prospective plan, prompts, generator, fixtures, harness and scorer were hashed before generating six new targets, two from each of three families: volume bands, graduated bands and minimum/rebate rules. Target files were committed by hash before the agents started. Forty-two fresh ephemeral agents used gpt-6-astra with max reasoning effort, seven policies per target, in randomised order with at most three concurrent cells. They received only bounded REA observation functions, synthetic product access and a numeric predictor schema; no target family, source repository, prior answers or score feedback. Each agent saved a predictor at a 96-request/24-REA-operation allowance and continued the same thread and application state to a 192-request/48-operation allowance. Denials consume request budget. A stage has a 30-minute ceiling. Actual usage may be lower. Every first checkpoint was hashed before continuation. After all 84 checkpoints were frozen, 256 common holdouts per target were selected excluding the union of every successful observation across all seven arms and both stages. Parameters were then released. No score-selected reruns were used.

The model weights are not claimed to be different from the previous study. Max is a higher configured single-agent reasoning effort than the earlier high setting, verified by the resolved app-server configuration and a separate excluded inference pilot. Ultra was not chosen because the local catalog described automatic delegation. A catalog entry is not proof of account access. The 96-to-192 comparison includes continued reasoning and context as well as additional request allowance; it does not isolate query count alone. Fresh targets, policies and effort also differ from the prior 24-request study, so cross-study changes are not a causal estimate of model strength.

Measured effectiveness

Defence	Exact accuracy	Within 5%	Exact reduction (pp)	Within 5% reduction (pp)
Exact estimates	100.0%	100.0%	0.0	0.0
Eight-quantity cap	54.4%	60.0%	+45.6	+40.0
GBP 1,000 rounding	31.2%	88.2%	+68.8	+11.8
GBP 1,000 rounding + cap	6.6%	39.6%	+93.4	+60.4
GBP 100 rounding + cap	21.5%	68.0%	+78.5	+32.0
GBP 100 rounding + catalogue	25.3%	96.8%	+74.7	+3.2
Approved outputs only	7.6%	18.3%	+92.4	+81.7

Primary accuracy measures the original underlying price on 256 common unobserved integer quantities per target, not a whole-product clone. Exact means the same integer number of pence; within 5% permits a relative error of at most 5%. A one-penny error fails exact accuracy. Reduction is baseline minus defended accuracy in percentage points. Positive reduction is helpful; negative reduction means the defended agent scored better. The primary score includes unsupported quantities for restricted products, so it measures hidden-rule inference, not just copying what customers can use.

Combining controls and continuing the investigation

Comparison at 192	Additional exact reduction (pp)	Additional within 5% reduction (pp)	Within 5% reduction range (pp)
GBP 1,000 rounding + cap versus GBP 1,000 rounding	+24.6	+48.6	+29.3 to +75.8
GBP 1,000 rounding + cap versus Eight-quantity cap	+47.8	+20.3	0.0 to +52.0
GBP 100 rounding + cap versus Eight-quantity cap	+32.8	-8.0	-39.5 to +41.8
GBP 100 rounding + cap versus GBP 1,000 rounding + cap	-15.0	-28.3	-67.2 to -2.3

Positive means an additional reduction from the first configuration. Only coarse rounding plus cap has both single-control comparators. Gentle rounding and catalogue contributions are not separately isolated.

Defence	Within 5% at 96	Within 5% at 192	Change (pp)
Exact estimates	100.0%	100.0%	0.0
Eight-quantity cap	60.0%	60.0%	0.0
GBP 1,000 rounding	88.2%	88.2%	0.0
GBP 1,000 rounding + cap	39.6%	39.6%	0.0
GBP 100 rounding + cap	68.0%	68.0%	0.0
GBP 100 rounding + catalogue	96.8%	96.8%	0.0
Approved outputs only	18.3%	18.3%	0.0

The identical checkpoint scores were investigated: **all 42/42 agents retained their numeric segment coefficients**, while every agent changed its notes. They made 1,342 additional requests, from 1,858 cumulative attempts at the first checkpoint to 3,200 at the second. The verifier matches each checkpoint to the corresponding stage's actual final response, so this is not reuse of the first file by the harness. The continuation prompt explicitly allowed retaining a predictor; anchoring and an observation-consistent model may contribute. This finding does not prove that extra queries, a fresh independent agent or a numerical fitting tool cannot improve accuracy. Read diagnostics.json for every cell.

The same agents continued without feedback. More allowance can improve a reconstruction, leave it unchanged, or lead to a worse submitted model. Both checkpoints remain in the evidence.

Keeping the SaaS useful

Defence	Estimates served	Estimates within 5%	Targets passing short criterion
Exact estimates	100.0%	100.0%	6/6
Eight-quantity cap	100.0%	100.0%	6/6
GBP 1,000 rounding	100.0%	5.6%	0/6
GBP 1,000 rounding + cap	100.0%	5.6%	0/6
GBP 100 rounding + cap	100.0%	91.7%	4/6
GBP 100 rounding + catalogue	100.0%	91.7%	4/6
Approved outputs only	0.0%	0.0%	0/6

All arms expose the same two exact approved quantities, 50 and 200, through both approved quote and approved export routes. These four actions remain available outside the estimate cap; they are an intentional disclosure channel included in attacker observations. These are synthetic quote/export JSON responses, not real payment, order fulfilment or file-generation tests. The cap is eight distinct estimate quantities shared across aliases and two sessions of the same tenant; repeat quantities do not spend it again. The 16-entry catalogue supports a finite published set. Approval is server-owned; arbitrary request IDs or extra client authority are rejected.

The short-workflow threshold was frozen in advance: every exact approved action must succeed correctly, at least 95% of estimate attempts must be served, and at least 95% of all estimate attempts must be within 5% of the true price. Every target must pass separately. Six estimates per target mean all six must meet each percentage threshold. Denied estimates count as failures. The planning journey requests 12 distinct estimates; free-form requests 12 non-catalogue quantities; after-exhaustion first spends eight distinct quantities with one session then repeats the short journey with a second session. Each ends with four exact quote/export actions. Utility uses direct HTTP on fresh fixtures with the same permissions, not REA or preferential good-user accounts. These proxies do not establish real customer satisfaction, accessibility, conversion, latency SLOs or production capacity.

A useful design calculation is independent of the agent results: nearest-step rounding changes a price by at most half the rounding step. To guarantee no more than 5% relative error from rounding alone, the true price must be at least ten times the step. GBP 100 rounding therefore guarantees that bound for prices of GBP 1,000 or more; GBP 1,000 rounding requires prices of GBP 10,000 or more. This is an arithmetic bound, not proof of reconstruction resistance. The same approximate outputs that help a customer can also help an entitled observer.

Defence	Planning: served / within 5%	Free-form: served / within 5%	After exhaustion: served / within 5%
Exact estimates	100.0% / 100.0%	100.0% / 100.0%	100.0% / 100.0%
Eight-quantity cap	66.7% / 66.7%	66.7% / 66.7%	0.0% / 0.0%
GBP 1,000 rounding	100.0% / 12.5%	100.0% / 30.6%	100.0% / 5.6%
GBP 1,000 rounding + cap	66.7% / 6.9%	66.7% / 12.5%	0.0% / 0.0%
GBP 100 rounding + cap	66.7% / 61.1%	66.7% / 59.7%	0.0% / 0.0%
GBP 100 rounding + catalogue	100.0% / 94.4%	0.0% / 0.0%	100.0% / 91.7%
Approved outputs only	0.0% / 0.0%	0.0% / 0.0%	0.0% / 0.0%

The remaining product can still be copied

Defence	Supported output exact	Supported output within 5%	Evaluation scope
Exact estimates	100.0%	100.0%	256 common unseen inputs
Eight-quantity cap	54.4%	60.0%	256 common unseen inputs
GBP 1,000 rounding	100.0%	100.0%	256 common unseen inputs
GBP 1,000 rounding + cap	69.5%	69.5%	256 common unseen inputs
GBP 100 rounding + cap	55.7%	66.4%	256 common unseen inputs
GBP 100 rounding + catalogue	100.0%	100.0%	16 catalogue inputs
Approved outputs only	100.0%	100.0%	Two approved inputs

These secondary scores measure delivered numeric outputs after public rounding. Approved and catalogue inputs may already have been observed; they are not held-out tests. They reuse predictors submitted for hidden prices, not a separately optimised memorising clone. A low secondary score therefore does not show that a lookup-table copy would fail. A low private-rule score does not establish that supported product behaviour is safe from imitation. Shared quota state, UI, accessibility, workflow fidelity and integrations are outside this numeric imitation score.

Supplementary analysis added after the protocol freeze: a lookup table replays only outputs that the same agent had already successfully observed by that checkpoint. Unknown quantities abstain. The table below scores the complete finite supported input set for each of six targets; repeated observations do not increase coverage. It uses no new requests, fitting or model inference. This is replay of observed numeric behaviour, not an independent attacker trial, held-out inference or a UI/state-machine clone. The mappings and source operation/row references are retained in memorisation.json and checked by the verifier.

Restricted product	Request allowance	Observed / supported inputs	Exact lookup replay
GBP 100 rounding + catalogue	96	96 / 96	100.0%
Approved outputs only	96	12 / 12	100.0%
GBP 100 rounding + catalogue	192	96 / 96	100.0%
Approved outputs only	192	12 / 12	100.0%

What developers, architects and product managers should do

- Keep proprietary rules and sensitive data on the server. Return only the result and precision necessary for the entitled task. Check delivered bundles, source maps, debug routes and response fields together; earlier negative controls show that fixing only one channel can leave the rule exposed.

- Enforce identity, tenant, object and action authorisation on every route, export and job. Use server-owned approvals and reject client-supplied authority. A self-service approval that accepts arbitrary quantities can restore the same inference oracle.

- Where the product permits it, combine output precision limits with a shared observation budget. Count distinct information-bearing inputs across aliases and sessions. Use durable atomic enforcement across replicas in production; this fixture does not establish that property.

- Treat exact approvals as information leakage too. Bound their creation according to real business entitlement. Do not assume that hiding an estimate route protects a rule while unrestricted invoices, exports, support tools or jobs reveal exact outputs.

- Measure approximate accuracy alongside exact matches. Use paired unseen inputs and actual permitted workflows, retain failures, and report all target results. A low exact score can coexist with a useful competing approximation.

- Set usefulness thresholds from real customer tasks before testing. Include longer planning, free-form exploration and another customer affected by a shared quota. Provide an appropriate recovery or support path without silently reopening arbitrary exact queries; validate that path too.

- Product managers should explicitly choose which information is part of the product promise. A finite catalogue or approval-only product can withhold arbitrary behaviour, but reduces flexibility and does not hide the outputs it sells. No measured control here guarantees that a useful public interface cannot be recreated.

Evidence, limitations and safe handling

The new evidence contains **340 real REA operations**, **3200 matched business response rows**, **7080 checked captured-body digests**, **21,504 held-out predictions**, **84,000 full-domain diagnostic predictions**, and **168 customer journeys** with 2520 HTTP actions including prefill. There are **84/84 valid predictors** and **0 failed or invalid predictors**. Failed predictors score zero and are not evidence of a successful defence. Capture coverage flags remain visible: incomplete 340. Specific matched responses support conclusions; incomplete capture does not become complete coverage. The repository total is 638 measured REA operations and 58 passing application/scoring tests. Recorded final cumulative tokens total 8,409,317; earlier checkpoint totals are not added again. Tokens are not a monetary cost estimate.

Six paired synthetic targets and one attempt per cell provide no repeated-agent variance estimate, confidence bound or population guarantee. There is no independent human white team, production deployment trial or whole-SaaS reconstruction measure. The numeric schema constrains the agent and can represent the target families. No general code-execution or numerical fitting tool was exposed; model arithmetic may underperform an attacker using external regression software. This study does not bound such attackers. Provider model identifiers do not pin independent model weights. No open-ended multi-account collusion, quota reset window, distributed race or full browser capability search was included. The new study covers quotes and exports; jobs remain an earlier separate boundary test. More agents, realistic outputs and longer observation windows may recover more information. A hard denial of an unauthorised request is distinct from preventing approximate inference from permitted outputs.

Only owned loopback fixtures, fresh synthetic pricing rules, disposable browser profiles and generated study sessions were used. Model inference uses the configured Codex service and synthetic observations. Agent shell, environment access, external browsing, apps, plugins, memories and inherited Node MCP access were disabled; completed out-of-scope operations invalidate an attempt. Session values use REA secret references and header-value capture is disabled. Public records exclude private account/engine events and private reasoning streams. Publication checks cover files, PDF text and metadata, archive contents and decoded captured bodies. This is a controlled study on a trusted laptop, not an OS/VM isolation certification or a guarantee about every host process.

The earlier studies demonstrate exact request denials for authentication, revocation, tenant and action boundaries; smaller delivered responses; and consistent approval checks across quotes, exports and jobs. Those results complement this accuracy study. An observed hard block is a precisely scoped refusal, not proof that REA stops running or cannot infer permitted behaviour.

Evidence and reproduction

Read the prospective plan, reproduction guide, raw run evidence, verification result and all per-input scores. The source-level REA explanation links the pinned implementation. The earlier agent benchmark and workflow boundary findings retain their original scope. Official background: model selection and Codex app-server access semantics.

For all target-level results and observed ranges, use the full combination scorecard. Both research and developer packs include the new protocol and human-readable reports.